
GCVE-BCP-07 - Known Exploited Vulnerability - KEV Assertion Format

GCVE.eu



Contents

Known Exploited Vulnerability - KEV Assertion Format	3
Introduction	3
Known Exploited Vulnerability - KEV Assertion Format	4
Format	4
Sample	6
Field Description	7
vulnerability Object	7
vulnerability.vulnId	7
status Object	7
status.exploited	7
status.status_reason	7
status.status_updated_at	7
characteristics Object	7
characteristics.remote_code_execution	8
characteristics.authentication_required	8
characteristics.local_access_required	8
timestamps Object	8
timestamps.first_seen_at	8
timestamps.asserted_at	8
timestamps.recorded_at	8
timestamps.last_seen_at	9
scope Object	9
scope.observation_regions	9
scope.victim_countries	9
scope.sector	9
scope.asset_exposure	9
scope.notes	9
evidence Array	10
evidence[].type	10
evidence[].signal	10

evidence[].confidence	10
evidence[].source	10
evidence[].details	10

Known Exploited Vulnerability - KEV Assertion Format



GCVE.eu

- **Version:** 1.0
- **Status:** Draft (for **Public Review**)
- **Date:** 2026-01-03
- **Authors:** GCVE Working Group
- **BCP ID:** BCP-07

This guide is distributed and available under **CC-BY-4.0**.

Copyright (C) 2025-2026 GCVE Initiative.

Introduction

Known Exploited Vulnerabilities (KEVs) have become a critical signal for vulnerability prioritization, operational risk management, and policy-driven remediation. Governments, CSIRTs, and sectoral authorities increasingly rely on KEV lists to mandate patching, trigger incident response, or inform compliance decisions. However, existing KEV publications are largely list-based and opaque, often asserting exploitation without clearly expressing who made the claim, when exploitation was observed versus declared, what type of evidence supports it, where it was seen, or with what level of confidence. As KEV data is increasingly consumed by automated systems and cross-border information-sharing mechanisms, the absence of structured, contextual metadata limits interoperability, trust calibration, and analytical reuse.

This Best Current Practice defines a standardized KEV assertion format that preserves the intentionally simple and binary nature of KEV while adding minimal but essential context. Within the GCVE or other ecosystem, where vulnerabilities may be disclosed and referenced by multiple independent authorities, exploitation claims must be clearly distinguishable from vulnerability identifiers and treated as attributable statements rather than universal truths. The format enables multiple, potentially conflicting assertions to coexist, supports explicit attribution and confidence signaling, and facilitates in-

teroperability with existing vulnerability, CSIRT, and policy ecosystems without turning KEV into full threat intelligence or requiring disclosure of sensitive evidence.

Known Exploited Vulnerability - KEV Assertion Format

This format describes a **generic KEV (Known Exploited Vulnerability) assertion format**.

The goal is to express *who claims exploitation, when, based on what, where it was observed, and with which level of confidence*, without turning KEV into full threat intelligence. A KEV assertion is usually very binary and lacking some meta-information. The format adds some information which could better capture details about the exploitation. A majority of the fields are optional except *vulnerability*, *status* and *evidence*. `[]`. *source* which are recommended.

Format

It's a single JSON object (ECMA 404) per KEV entry. The KEV entry is associated to a vulnerability ID in GCVE ID or any known vulnerability identifier.

Sample

```

1  {
2  "vulnerability": {
3    "vulnId": "GCVE-0-2025-55182"
4  },
5  "status": {
6    "exploited": true,
7    "status_reason": "confirmed",
8    "status_updated_at": "2025-12-24T10:15:00Z"
9  },
10 "characteristics": {
11   "remote_code_execution": true,
12   "authentication_required": false,
13   "local_access_required": false
14 },
15 "timestamps": {
16   "first_seen_at": "2025-12-03T10:15:00Z",
17   "asserted_at": "2025-12-05T12:10:11Z",
18   "recorded_at": "2025-12-05T13:15:00Z",
19   "last_seen_at": "2025-12-24T09:42:21Z"
20 },
21 "scope": {
22   "observation_regions": ["Europe", "North America"],
23   "victim_countries": ["LU", "BE", "US", "CA"],
24   "sector": ["Telecoms", "Aerospace"],
25   "asset_exposure": ["internet-facing"],
26   "notes": "Regions reflect observed evidence, not global exclusivity"
27 },
28 "evidence": [
29   {
30     "type": "incident_response",
31     "signal": "confirmed_compromise",
32     "confidence": 0.9,
33     "source": "national-csirt",
34     "details": {
35       "observed_outcome": ["initial-access", "rce"],
36       "detection_basis": ["forensics", "log-analysis"]
37     }
38   },
39   {
40     "type": "honeypot",
41     "signal": "in_the_wild_attempts",
42     "confidence": 0.6,
43     "source": "research-honeynet",
44     "details": {
45       "attempt_volume": "high",
46       "successful_exploitation": false
47     }
48   }
49 ],
50 "references": [
51   {
52     "id": "GCVE-0-2025-55182",
53     "url": "https://vulnerability.circl.lu/vuln/CVE-2025-55182#sightings"
54   }
55 ],
56 }

```

Field Description

vulnerability Object Describes the vulnerability being asserted as exploited.

vulnerability.vulnId

- **Type:** string
- **Required:** yes
- **Description:** GCVE, CVE identifier, GHSA or any identifier of the vulnerability.
- **Example:** "GCVE-0-2025-55182"

status Object Represents the current exploitation status.

status.exploited

- **Type:** boolean
- **Description:** Indicates whether exploitation has been observed or asserted.
- **Semantics:** Does not imply global prevalence or universal exploitability.

status.status_reason

- **Type:** string (enum)
- **Allowed values:** `confirmed`, `suspected`, `disputed`, `historical`, `unknown`
- **Description:** Rationale behind the exploitation status.

status.status_updated_at

- **Type:** string (RFC3339 datetime)
- **Description:** Timestamp of the last change to the exploitation status in the KEV assertion.

characteristics Object Describes high-level technical characteristics of the vulnerability that are relevant to exploitation assessment, without providing exploit details or turning the KEV assertion into full threat intelligence.

These fields describe properties of the vulnerability itself, not necessarily every observed exploitation instance.

characteristics.remote_code_execution

- **Type:** boolean
- **Description:** Indicates whether successful exploitation can result in remote code execution.
- **Notes:** Does not imply exploit reliability or ease of weaponization.

characteristics.authentication_required

- **Type:** boolean
- **Description:** Indicates whether authentication is required to exploit the vulnerability.
- **Notes:** Reflects the weakest known exploitation path.

characteristics.local_access_required

- **Type:** boolean
- **Description:** Indicates whether local system access is required prior to exploitation.
- **Notes:** Useful to distinguish remote exploitation from post-compromise privilege escalation.

timestamps Object Separates different notions of time to avoid ambiguity.

timestamps.first_seen_at

- **Type:** string (RFC3339 datetime)
- **Description:** Earliest known exploitation activity based on technical observation.
- **Notes:** May be estimated and updated retroactively.

timestamps.asserted_at

- **Type:** string (RFC3339 datetime)
- **Description:** Date when an authority or source officially declared exploitation.
- **Notes:** Mirrors fields such as “date added” in KEV lists.

timestamps.recorded_at

- **Type:** string (RFC3339 datetime)
- **Description:** Timestamp when this assertion was ingested or recorded by the collector.
- **Notes:** System-specific and independent of the source.

timestamps.last_seen_at

- **Type:** string (RFC3339 datetime)
- **Description:** Most recent confirmed observation of exploitation activity.
- **Notes:** Optional and often unavailable.

scope.Object Defines the observed context of exploitation.

scope.observation_regions

- **Type:** array of strings
- **Description:** Geographic regions where exploitation evidence was observed. The region can be described in **UN M49** format to facilitate automation.
- **Notes:** Reflects sensor or reporting coverage, not global limits.

scope.victim_countries

- **Type:** array of strings
- **Description:** Countries in ISO 3166 where confirmed victims were identified.
- **Notes:** Often incomplete or unavailable.

scope.sector

- **Type:** array of strings
- **Description:** Sectors targeted or affected by exploitation. The sector **SHALL** come from the **MISP galaxy sector**.
- **Example:** "Telecoms", "Aerospace"

scope.asset_exposure

- **Type:** array of strings
- **Allowed values:** internet-facing, internal, vpn-accessible, unknown
- **Description:** Exposure context of affected assets.

scope.notes

- **Type:** string
- **Description:** Human-readable clarifications to prevent misinterpretation.

evidence Array Collection of independent signals supporting the exploitation claim.

evidence[].type

- **Type:** string (enum)
- **Allowed values:** `incident_response`, `telemetry`, `honeypot`, `sinkhole`, `vendor_report`, `research_report`, `unknown`
- **Description:** Origin of the exploitation evidence.

evidence[].signal

- **Type:** string (enum)
- **Allowed values: (can be multiple)** `in_the_wild_attempts`, `successful_exploitation`, `confirmed_compromise`, `mass_scanning`, `weaponized_exploit_available`
- **Description:** Nature of the observed exploitation signal.

evidence[].confidence

- **Type:** number (0.0–1.0) or enum
- **Description:** Confidence level associated with this evidence.

evidence[].source

- **Type:** string
- **Description:** Logical identifier of the reporting entity or data source. MISP org UUID? What about existing KEV source like CISA, ENISA or alike. Should we have an enum with existing ones? The source would be the only required fields has many KEV like the type of signal.

evidence[].details

- **Type:** object
- **Description:** Structured, free-form metadata describing how the signal was derived.
- **Notes:** Content is implementation-specific.